Preventing Cryptographic Failures

- **Encrypt HTTP session:** Protect sensitive data at rest and in transit (TLS 1.2+, preferably TLS 1.3)

- **Enforce secure communication:**
  - Valid certificates
  - Use `secure` cookie flag with authentication cookie
  - Enable HTTP Strict Transport Security (HSTS)

- **Hash passwords securely:** Use salted, slow password hashing (Argon2id, scrypt)

A05 - Injection

- **Problem:** Untrusted user input is interpreted as executable commands or queries
- **Impact:** Unauthorized data access, modification, deletion, or arbitrary code execution

Common vulnerabilities:

- **SQL/NoSQL injection:** Manipulating database queries
- **Command injection:** Executing arbitrary OS commands
- **Other injections:** LDAP, ORM, or expression language injection
- **Unsafe input handling:** Concatenating untrusted data into queries or commands
- **Insufficient validation:** Failing to validate or sanitize user input